

1.5 Customer Environment Protection

Control Type: Mandatory	Applies to architecture:	A1	A2	A3	A4	B
					•	
<u>Control Definition</u> Control Objective: Ensure the protection of the customer's connectivity infrastructure from external environment and potentially compromised elements of the general IT environment. In-scope components: - customer connector - dedicated and general-purpose operator PCs - jump server - HSM when used with customer connector - Alliance Connect Virtual on Premises VPN [Advisory: customer client connector] Risk Drivers: - compromise of enterprise authentication system - compromise of user credentials - credential replay - exposure to internet-based attacks - unauthorised access						
<u>Implementation Guidance</u> Note: This control focuses on the customer connector and expects separation between (i) operational (or production) environment where the customer connector resides and (ii) the wider or general IT environment. Control Statement: A separated secure zone safeguards the customer's infrastructure used for external connectivity from external environments and compromises or attacks on the broader enterprise environment. Control Context: Segmentation between the customer's connectivity infrastructure and its larger enterprise network reduces the attack surface and has shown to be an effective way to defend against cyber-attacks that commonly involve compromise of the general enterprise IT environment. Effective segmentation will include network-level separation, access restrictions, and connectivity restrictions. Implementation Guidelines: The implementation guidelines are common methods to apply the relevant control. The guidelines are a helpful way to begin an assessment but should never be considered as an audit checklist as each user's implementation may vary. Therefore, in cases where some implementation guidelines elements are not present or partially covered, mitigations as well as particular environment specificities must be considered to properly assess the overall compliance adherence level (as per the suggested guidelines or as per the alternatives). a) Overall design goals for implementing environment separation Implement a secure zone (or restricted operational zone) to separate and protect the customer connectivity infrastructure from the compromise of systems and services located outside of the secure zone.						

- To the fullest extent possible, passwords and other authenticators that are usable inside the secure zone (especially for privileged accounts) are not stored or used in systems outside of the secure zone. This does not apply to encrypted back-up files.
- If the authentication services system resides outside of the secure zone, then:
 - Either the system is in another existing secure zone that has similar controls,
 - or the system is only used to filter the connections to the customer's connectivity infrastructure (controlling the accesses at the boundary of the secure zone). In such a case, logical access to the component is ensured by another authentication mechanism residing in the secure zone (by another IAM or is performed by the accessed component itself).
- The secure zone is appropriately scoped to each user's environment, including the potential reuse of existing secure zones (for example, a secure "production environment", "back-office environment", or "payment systems zone") to include the connectivity infrastructure.
- The components within the secure zone are all protected to the same or an equivalent level of security and trust and those components may communicate freely within the zone. Primary purpose of a secure zone is to contain and protect Swift-related systems but it can also include non-Swift related systems which then also need to be adequately protected by applying controls applicable to the Swift-related systems and their related Swift-related components.

b) Scope of the secure zone

- The secure zone contains, but is not limited to, all components of the connectivity infrastructure. This includes the Hardware Security Module (when relevant), the Alliance Connect Virtual on Premises VPN, the customer connector, the jump server (see details below), and any applicable operator PCs solely dedicated to the operation or administration of the connectivity infrastructure. As such:
 - General-purpose operator PCs are not included in the secure zone.
 - Dedicated operator PCs with "thick client" GUI software are located in the secure zone, or the software is installed on the jump server and accessed by the general-purpose operator PCs residing outside of the secure zone.
 - Back-office systems are not necessarily included in the secure zone, but may be considered for inclusion depending on the chosen size and scope of the secure zone.
 - Test systems are not considered in scope of the security controls as long as (i) they are fully separated from production or live environment (including separate HSMs, when used) and (ii) they are configured to only support test traffic (for example, by only using lite certificates on test only logical terminals). If the test systems are not fully separated or can be configured for live traffic, then users must take the test systems in scope and make sure that the same security controls are applied as for production or live systems. Development systems are not within the secure zone and are not connected to the Swift network.
 - When used, all the Alliance Connect VPN boxes and the Alliance Connect Virtual VPN instances (hosting systems or machines) are in a secure environment with appropriate physical controls (aligned with control 3.1).
- The secure zone size and scope are defined in a way that is most appropriate to the user's environment. Options may include, but are not limited to the following:
 - A specific secure zone dedicated only for the connectivity infrastructure.
 - An expansion of an existing secure area (for example, a secure "production environment" or "payment systems zone") to include the connectivity infrastructure. The size and scope of this zone may vary significantly depending on the existing environment.
- Software, systems, and services within the secure zone are assessed for need and removed from the zone if not supporting the operations or security of the zone (for example, assess the need for e-mail access).

c) Protection of the secure zone

Boundary Protection

- Transport layer stateful firewalls are used to create logical separations at the boundary of the secure zone.
 - Transport layer firewalls creating the secure zone boundary should be physically or virtually dedicated to the protection of the secure zone. If a firewall is shared to separate other zones, then care must be taken for the firewall management to make sure that compromises of the firewall do not affect the protection of the secure zone.

- Access control lists (ACLs) and application firewalls may be used to provide additional protection for the secure zone, but are not sufficient alone.
- Layer 2 devices (data link layer, such as switches) may be shared between the secure zone and other uses (VLAN separation).
- Administrative access to networking devices is protected using either an out-of-band network or through controlled in-band access (for example, a management VLAN or multi-factor authentication when remotely accessing externally exposed firewalls). Administrative access to the firewalls that protect the secure zone does not rely on the enterprise user authentication system, but a system located within an existing secure zone that has similar controls.
- Inbound and outbound connectivity for the secure zone is limited to the fullest extent possible. A process is implemented to analyse, review, and enforce the firewall rules governing the connectivity.
 - No “allow any” firewall rules are implemented, and network flows are explicitly authorised (allowlisting approach). To achieve this, a general enterprise server might initially be used to filter legitimate connectivity access towards the secure zone without losing traceability of such connections.
 - Generally, connectivity crossing the secure zone boundary is restricted to bi-directional communications with back-office applications and MV-SIPN¹⁹ or the Internet, inbound communications from approved general-purpose operator PCs to the jump server, and outbound administration data (data logging, back-ups).
 - Firewall rules are reviewed annually, at least.
 - Connections through the boundary firewalls are logged in line with or as part of the control 6.4.

d) Access to the secure zone systems

d.1 Local Operator (end user and administrator) Access

- The secure zone has implemented one of the following designs for restricting operator access (interactive or command-line sessions) into the secure zone:
 - Operators connect from dedicated operator PCs located within the secure zone (that is, PCs located within the secure zone, and used only for secure zone purposes).
 - Operators connect from their general-purpose operator PC to the secure zone through a jump server (for example, using a Citrix-type solution or Microsoft Terminal Server) located within the secure zone or within another existing secure zone that has similar controls.
As the entry point into the secure zone, the jump server implements strong security practices, including the following:
 - Make sure all in-scope security controls in this document are implemented (for example security updates, system hardening).
 - Separate jump server for system administrators (with multi-factor authentication) and end users. As an alternative to separate jump servers, only allow temporary access to system administrators with effective approval processes and session activity recording.
 - Restrict access to authorised operators only.
 - Remove any unnecessary software.
 - Restrict risky activity (for example, sending or receiving e-mails).
 - Enable logging in line with or as part of the control 6.4.
 - Operators connect from their general-purpose operator PC and only access the customer connector offering interactive access with a browser-based GUI. The following specific security controls apply to this set-up:
 - The browser-based GUI is located in the secure zone and is ideally, at network level, logically separated from the customer connector.
 - Multi-factor authentication is implemented, where appropriate (on the browser-based GUI or on the customer connector).
 - This set-up cannot be used for operating system administrative activities.
- Customer connectivity systems within the secure zone restrict administrative access to only expected ports, protocols, and originating IPs.

d.2 Remote Operator Access (teleworking, “on-call” duties, or remote administration)

- Remote access to the secure zone from outside of the user network first requires VPN authentication (recommended with multi-factor authentication) to the network before accessing the secure zone through the same secured channels as local operators.

¹⁹ Multi-Vendor Secure IP Network

- A risk assessment is performed by the user to consider additional security controls to be implemented for remote access, such as the use of a virtual desktop infrastructure, dedicated channels for connectivity (for example, dedicated jump servers for remote users, leased lines).

e) Separation from General Enterprise IT Services

- To protect the secure zone from credential theft or a compromise of enterprise authentication (LDAP, RADIUS, Identity Provider, multi-factor) services, or a combination of both, secure zone systems use a separate authentication system from the general enterprise authentication service. For example, secure zone systems are not a member of the corporate directory service, but are instead members of a secure zone directory service.
- Supporting IT infrastructure, such as asset management, databases, data storage, security services (for example, patching), and networking services (for example, DNS, NTP) used within the secure zone is protected from credential compromise within the larger enterprise. Institutions must conduct an analysis of connectivity points which make sure that these systems do not store authenticators (passwords, tokens, and other methods) for systems and accounts in scope in any format (hashed, encrypted, plain text) outside of the secure zone or another existing secure zone that has similar controls. The supporting IT infrastructure should not be exclusive to Swift systems and may be shared within the secure zones.

Optional Enhancements:

- Restrict (through additional separation) the communication between components of the secure zone considering the following:
 - Network ACLs or host-based firewalls that restrict traffic on a host-by-host basis within the secure zone.
- Individual hardware or network-based firewalls between the components in the secure zone can optionally be used.

Considerations for alternative implementations:

Institutions with a high level of security programme maturity within the organisation might consider implementing alternative controls such as those suggested below or others. The alternative solutions must be risk-appropriate to each environment, and must consider the effort required to effectively implement, manage, and maintain the solution.

- Not separating secure zone authentication services from the enterprise authentication service will require implementing a comprehensive set of defence-in-depth controls to protect from and detect adversaries that cross the secure zone boundary. Controls may include locating the authentication service within an existing secure zone with similar controls as those applicable to the secure zone, limiting trust relationships between the larger enterprise environment and the secure zone (such as one-way trust relationships), restricting operator and administrative access, implementing strong privileged access controls, implementing read-only access where feasible, enabling verbose logging, and implementing centralised active monitoring and detective capabilities.
- If general enterprise IT services (for example, vulnerability scanning and boundary firewall management) are shared between the secure zone and other environments, then any credentials used across the environment should be monitored to make sure they are only used when and where expected.
- If a general enterprise server is initially used to reach the secure zone, then that server is only used to filter legitimate connectivity access (as a concentrator or gateway to ease access filtering to the secure zone). Identity and access management for secure zone components or the jump server (or both) still rely on authentication services that reside within the secure zone or another existing secure zone that has similar controls.
- If the secure zone has dependencies on enterprise shared functions (such as directory services, servers, or networks) that are outside the scope, then the user must make sure that any compromise of such functions will not compromise the security of the in-scope components.